

VORBEREITUNG ZUR VORLESUNG

Handout 06 – Secrets und Konfiguration

Modul 3IT-VSIT-50 · Verteilte Systeme und Internet der Dinge
Thema Passwörter richtig behandeln
Dozent Dr. Ulrich Winkler
Semester 5. Semester · Informationstechnik

Konfiguration gehört nach außen – aber Geheimnisse besonders

Es gilt als gute Praxis, Einstellungen über Umgebungsvariablen hereinzureichen (Handout 03). Für **Geheimnisse** – Passwörter, API-Schlüssel, Zertifikate – reicht das aber nicht, denn Umgebungsvariablen sind erstaunlich leicht auslesbar.

Warum Env-Variablen für Passwörter problematisch sind

- **docker inspect** zeigt alle Umgebungsvariablen eines Containers im Klartext.
- Sie tauchen oft in **Logs**, Fehlermeldungen und Crash-Reports auf.
- Kind-Prozesse **erben** sie; ein Leck an einer Stelle betrifft viele.
- In einer **compose.yaml** im Repository stünde das Passwort für jeden lesbar da.

In Übung 06 führen Sie dieses Leck selbst vor: ein Passwort per **-e** gesetzt, mit **docker inspect** wieder herausgezogen.

Docker-Secrets: das Passwort als Datei

Compose kennt **file-based secrets**. Das Geheimnis liegt in einer eigenen Datei und wird zur Laufzeit unter **/run/secrets/<name>** in den Container eingeblendet:

```
services:
  db:
    environment:
      POSTGRES_PASSWORD_FILE: /run/secrets/db_password
    secrets: [ db_password ]
secrets:
  db_password:
    file: ./db_password.txt
```

Viele offizielle Images (darunter **postgres**) unterstützen die ***_FILE**-Variante einer Einstellung ausdrücklich. Unser **log_tool** liest das Passwort ebenfalls aus **DB_PASSWORD_FILE**. Ergebnis: In der **compose.yaml** steht **kein** Klartext-Passwort mehr, und **docker inspect** zeigt nur noch den *Dateipfad*, nicht das Geheimnis.

Eiserne Regel

Geheimnisse gehören niemals ins Git-Repository. Committen Sie nur eine harmlose Vorlage (db_password.txt.example); die echte Datei db_password.txt schließt die .gitignore aus.

Secrets in Docker Swarm

Compose-Secrets sind letztlich Dateien auf dem Wirt. Für den Produktionsbetrieb bietet **Docker Swarm** einen echten, **verschlüsselten** Secret-Speicher:

```
docker swarm init
printf 'streng-geheim' | docker secret create db_password -
```

Das Secret wird im Cluster verschlüsselt abgelegt und nur den Diensten zugänglich gemacht, die es ausdrücklich anfordern – und dort ebenfalls unter `/run/secrets/`. Mehr zu Swarm im Zusatz-Handout (Übung 09).

Secret-Rotation

Geheimnisse sollten sich **wechseln** lassen, ohne die Anwendung umzubauen. Weil unser Code das Passwort aus einer Datei bzw. Variablen liest und nichts fest verdrahtet, genügt es, das Secret auszutauschen und die Dienste neu zu starten. Wird ein Passwort versehentlich öffentlich (z. B. in einem Commit), lautet die Regel: **sofort rotieren** – ein einmal geleaktes Geheimnis gilt als verbrannt.